mTLS Handshake Analysis

Client Identity Exposure Across TLS Versions

Findings from live packet capture analysis of TLS 1.0 through 1.3

Bill Church
VP Engineering and Services | Tailwind Resource Group
bill@tailwindrg.com

TAILWIND
Resource Group

What is mTLS?

Mutual TLS Authentication

In standard TLS, only the server proves its identity. With mTLS, **both client and server** exchange certificates during the handshake.

Common in government (PIV/CAC), zero-trust architectures, and service mesh deployments.

Client Certificates Contain PII

Certificates include the holder's full name, unique identifiers, organizational affiliations, and PKI infrastructure details.

The Privacy Problem

In TLS 1.0-1.2, the client certificate is sent **before encryption begins**. Any passive network observer can extract the client's full identity.

This means a simple packet capture reveals:

- Subject DN (full name + ID number)
- SAN URIs and email addresses
- Certificate policies and issuer chain
- CRL/OCSP endpoint URLs

TAILWIND
Resources Group

TLS 1.0 - 1.2 Handshake

Client identity exposed in cleartext

1. Client → Server
   ClientHello — negotiate parameters, cipher suites

2. Server → Client
   ServerHello, Certificate, ServerKeyExchange, CertificateRequest, ServerHelloDone

CLEARTEXT — Visible to passive observers

3. Client → Server
   Certificate, ClientKeyExchange, CertificateVerify
   CN=DOE.JOHN.1234567890 | UUID, email, OCSP, CRL — ALL IN THE CLEAR

4. Client → Server
   ChangeCipherSpec, Finished — encryption begins here

5. Server → Client
   NewSessionTicket, ChangeCipherSpec, Finished

Cipher suites: TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA (1.0/1.1) | TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 (1.2)

TAILWIND
Research Group

What a Passive Observer Sees (TLS 1.0-1.2)

Extracted from Client Certificate

Subject DN	`CN=DOE.JOHN.1234567890`
SAN UUID	`urn:uuid:f81d4fae-7dec-11d0-a765-00a0c91e6bf6`
SAN Email	`john.doe@test.gov`
OCSP URI	`http://ocsp.test.gov/piv`
CA Certificate	`http://pki.test.gov/certs/PIVAuthCA.cer`
CRL	`http://pki.test.gov/crl/PIVAuthCA.crl`

Impact

Identity Tracking

Full name and EDIPI visible — enables tracking individuals across network sessions.

Organizational Mapping

Certificate policies and issuer chain reveal employer, agency, and PKI hierarchy.

Infrastructure Discovery

OCSP/CRL URIs expose internal PKI infrastructure endpoints.

An adversary with passive access to network traffic can silently harvest this data without any active probing.

TAILWIND
Research Group

TLS 1.3 Handshake

Client identity fully encrypted

1. Client → Server
   ClientHello — includes key share for immediate encryption
2. Server → Client
   ServerHello, ChangeCipherSpec — key exchange complete

ENCRYPTED — All subsequent messages protected

3. Server → Client (encrypted)
   EncryptedExtensions, Certificate, CertificateVerify, Finished
4. Client → Server (encrypted)
   Certificate, CertificateVerify, Finished — client identity hidden

Cipher suite: TLS_AES_256_GCM_SHA384 (0x1302)

Identity Protection

Client certificate sent inside the encrypted tunnel. Passive observers see only opaque Application Data records.

Zero Metadata Leakage

CN, SAN, email, policy OIDs, CRL/OCSP URIs — none are visible on the wire.

Faster Handshake

1-RTT handshake (vs 2-RTT in TLS 1.2). Encryption starts immediately after ServerHello.

TAILWIND
Resources Group

Client Identity Visibility by TLS Version

TLS Version	Client Cert	Subject DN	SAN (UUID/Email)	Policy OIDs	CRL/OCSP URIs	Cipher Suite
TLS 1.0	CLEARTEXT	VISIBLE	VISIBLE	VISIBLE	VISIBLE	ECDHE_RSA_AES_256_CBC_SHA
TLS 1.1	CLEARTEXT	VISIBLE	VISIBLE	VISIBLE	VISIBLE	ECDHE_RSA_AES_256_CBC_SHA
TLS 1.2	CLEARTEXT	VISIBLE	VISIBLE	VISIBLE	VISIBLE	ECDHE_RSA_AES_256_GCM_SHA384
TLS 1.3	Encrypted	Encrypted	Encrypted	Encrypted	Encrypted	AES_256_GCM_SHA384

Data derived from live mTLS handshake packet captures across all four TLS versions.

TAILWIND
Resources Group

Why TLS 1.3 Is Different

TLS 1.0 - 1.2 Flow

1. ClientHello / ServerHello negotiate parameters
2. Server sends certificate and requests client's
3. **Client sends certificate IN THE CLEAR**
   Full identity visible to any observer
4. ChangeCipherSpec enables encryption
5. Finished messages verify handshake

TLS 1.3 Flow

1. ClientHello / ServerHello exchange key shares
2. **Encryption starts immediately**
   All subsequent messages encrypted
3. Server sends EncryptedExtensions, Certificate, CertificateVerify, Finished
4. **Client sends Certificate, CertificateVerify, Finished (ALL ENCRYPTED)**
   Identity never exposed on the wire

TAILWIND
Research Group

Key Takeaways

1

TLS 1.0-1.2 exposes client identity to passive observers

The mTLS client certificate — containing full name, unique IDs, email, organizational affiliation, and PKI infrastructure details — is transmitted in cleartext before encryption begins.

2

TLS 1.3 eliminates this exposure entirely

By restructuring the handshake to establish encryption immediately after the ServerHello, all certificate exchanges occur within the encrypted tunnel.

3

Mandate TLS 1.3 for mTLS deployments

Organizations using client certificates for authentication — especially those with PII in certificates (government PIV/CAC, enterprise PKI) — should enforce TLS 1.3 minimum.

Disabling TLS 1.0-1.2 is the only way to guarantee client identity protection from passive network surveillance.

TAILWIND
Resources Group

Appendix

Detailed Handshake Sequence Diagrams

Per-version message flows from live packet captures

TAILWIND
Resources Group

TLS 1.0 Handshake Flow

Client identity exposed in cleartext

Client
DOE.JOHN.1234567890

Server
localhost

ClientHello →

← ServerHello, Certificate, ServerKeyExchange, CertificateRequest, ServerHelloDone

CLIENT IDENTITY VISIBLE IN CLEARTEXT

Certificate, ClientKeyExchange, CertificateVerify →

Exposed on the wire:
CN=DOE.JOHN.1234567890 | urn:uuid:f81d4fae-7dec-11d0-a765-00a0c91e6bf6
john.doe@test.gov | http://ocsp.test.gov/piv | http://pki.test.gov/crl/PIVAuthCA.crl

ChangeCipherSpec, Finished →

← NewSessionTicket, ChangeCipherSpec

Cipher: TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA (0xc014)

TAILWIND
Research Group

TLS 1.1 Handshake Flow

Client identity exposed in cleartext

Client
DOE.JOHN.1234567890

Server
localhost

ClientHello →

← ServerHello, Certificate, ServerKeyExchange, CertificateRequest, ServerHelloDone

CLIENT IDENTITY VISIBLE IN CLEARTEXT

Certificate, ClientKeyExchange, CertificateVerify →

Exposed on the wire:
CN=DOE.JOHN.1234567890 | urn:uuid:f81d4fae-7dec-11d0-a765-00a0c91e6bf6
john.doe@test.gov | http://ocsp.test.gov/piv | http://pki.test.gov/crl/PIVAuthCA.crl

ChangeCipherSpec, Finished →

← NewSessionTicket, ChangeCipherSpec

Cipher: TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA (0xc014)

TAILWIND
Research Group

TLS 1.2 Handshake Flow

Client identity exposed in cleartext

Client
DOE.JOHN.1234567890

Server
localhost

ClientHello →

← ServerHello, Certificate, ServerKeyExchange, CertificateRequest, ServerHelloDone

CLIENT IDENTITY VISIBLE IN CLEARTEXT

Certificate, ClientKeyExchange, CertificateVerify →

Exposed on the wire:
CN=DOE.JOHN.1234567890 | urn:uuid:f81d4fae-7dec-11d0-a765-00a0c91e6bf6
john.doe@test.gov | http://ocsp.test.gov/piv | http://pki.test.gov/crl/PIVAuthCA.crl

ChangeCipherSpec, Finished →

← NewSessionTicket, ChangeCipherSpec

Note: TLS 1.2 uses stronger cipher (AES-256-GCM) but the handshake structure is identical to 1.0/1.1 — client cert still sent before encryption

Cipher: TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 (0xc030)

TAILWIND
Research Group

TLS 1.3 Handshake Flow

Client identity fully encrypted

Client
DOE.JOHN.1234567890

Server
localhost

ClientHello (includes key share) →

← ServerHello, ChangeCipherSpec

ENCRYPTED TUNNEL -- All messages below protected

← EncryptedExtensions, Certificate, CertificateVerify, Finished

ChangeCipherSpec →

Application Data (opaque to observers) ↔

Hidden from passive observers:
CN=DOE.JOHN.1234567890 | urn:uuid:f81d4fae-7dec-11d0-a765-00a0c91e6bf6
john.doe@test.gov | Policy OIDs | CRL/OCSP URIs | Full CA chain

Key difference: Encryption starts immediately after ServerHello. Client certificate is sent inside the encrypted tunnel, making it invisible to passive network observers.

Cipher: TLS_AES_256_GCM_SHA384 (0x1302)

TAILWIND
Resources Group

Appendix: Client Identity Visibility Summary

Data extracted from live mTLS handshake packet captures across all four TLS versions

TLS	Client Cert	Subject DN	SAN	Policy OIDs	CRL/OCSP	Cipher Suite	Key Difference
1.0	CLEARTEXT	VISIBLE	VISIBLE	VISIBLE	VISIBLE	ECDHE_RSA_AES_256_CBC_SHA	Cert before ChangeCipherSpec
1.1	CLEARTEXT	VISIBLE	VISIBLE	VISIBLE	VISIBLE	ECDHE_RSA_AES_256_CBC_SHA	Same as 1.0
1.2	CLEARTEXT	VISIBLE	VISIBLE	VISIBLE	VISIBLE	ECDHE_RSA_AES_256_GCM_SHA384	Stronger cipher, same exposure
1.3	Encrypted	Hidden	Hidden	Hidden	Hidden	AES_256_GCM_SHA384	Cert sent inside encrypted tunnel

Source: docs/handshake-comparison.md — generated from pcap analysis via tshark

TAILWIND
Research Group